

ORBIT Security Architecture

1. Introduction

ORBIT (Open Retrieval-Based Inference Toolkit) is an open-source AI gateway, retrieval engine, and agent protocol host. It can be deployed on-premises, in private cloud environments, or in isolated air-gapped networks.

ORBIT's core application code and gateway configuration features are distributed under the Apache 2.0 open-source license. Certain capabilities connect to separately operated infrastructure dependencies (e.g. external OIDC Identity Providers like Entra ID/Auth0, the self-hosted Presidio HTTP PII analyzer, cloud secret managers, or cloud object stores).

Achieving compliance for a specific deployment requires validating ORBIT's technical capabilities alongside deployment-specific operational controls, network security, host hardening, storage infrastructure, external service governance, and administrative procedures.

2. NIST SP 800-53 Rev. 5 Technical Control Mapping

This section maps ORBIT's documented features to NIST SP 800-53 (Rev. 5) control objectives using a three-part analysis:

1. **Documented Capability:** The specific feature implemented in ORBIT.
2. **Potential Control Contribution:** The NIST SP 800-53 control objective supported by the capability.

3. Deployment Evidence & Responsibilities Required: Mandatory operational procedures, infrastructure controls, and assessor evidence required.

2.1 Access Control (AC)

NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
AC-2 Account Management	Deny-by-Default Identity Allowlisting: <code>auth.providers.access_control: allowlist</code> enforces rule-based access control. External Entra ID and Auth0 users can be pre-cleared by email, user ID, or OIDC provider-subject before account provisioning (<code>orbit user allowlist</code> , Admin UI, <code>/auth/allowlist</code>).	Supports pre-provisioning verification and structured identity lifecycle management for federated accounts.	Evaluators must configure <code>auth.providers.access_control: allowlist</code> , verify rule synchronization, and review user provisioning logs. Reference: Authentication Guide .
AC-3 Access Enforcement	6-Role RBAC & Granular Permissions: Enforces 6 documented roles (<code>admin</code> , <code>operator</code> , <code>auditor</code> , <code>analyst</code> , <code>user-manager</code> , <code>user</code>) covering 11 discrete permissions. API keys can be bound to specific adapters, users, email allowlists, and request quotas.	Provides role-based enforcement over system routes, configuration management, and model proxy paths.	Assessors must verify role bindings in <code>users</code> and <code>api_keys</code> schema tables and review authorization test suites. Roadmap Note (Phase 6): Admin IP allowlisting (<code>auth.admin_ip_allowlist</code>) is planned to restrict admin dashboard access to designated CIDR ranges (Phase 6 Roadmap). References: RBAC Architecture , API Keys Guide .
AC-6 Least Privilege	OIDC Role Mapping & Adapter Scoping: Federated JWTs are cryptographically validated against configured IdPs and mapped to local ORBIT users with baseline role assignment set by <code>auth.providers.default_role</code> (defaults to <code>user</code>). Administrative permissions are assigned locally.	Enables least-privilege scoping for end-user chat/API sessions versus administrative sessions.	System administrators must audit <code>default_role</code> settings and verify that administrative permissions are granted only to vetted users. Reference: Authentication Guide .
AC-7 Unsuccessful Logon Attempts	Login Rate Limiting: Password and SSO login surfaces enforce configurable, cache-backed fixed-window limits using independent per-IP and normalized-username buckets, with an in-memory fallback when the cache is unavailable. Exceeded limits return HTTP 429 with retry and rate-limit headers.	Supports brute-force throttling and limits repeated unsuccessful authentication attempts against both source addresses and target identities.	System administrators must configure <code>auth.login_rate_limit</code> , verify the IP and username thresholds, confirm cache/fallback behavior, and review <code>auth.login.rate_limited</code> audit events. Account lockout after consecutive failures remains a separate future enhancement (Phase 3 Roadmap).

NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
AC-12 Session Termination	Allowlist Access Withdrawal: Removing or narrowing an allowlist rule revokes identity clearance. Active opaque dashboard sessions and provider JWT validation calls fail authorization on subsequent requests within the worker's cache TTL window.	Contributes to automated session and credential access revocation upon account status changes.	Evaluators must configure cache TTL values appropriately and test revocation propagation across multi-worker deployments. Roadmap Note (Phase 5): Active session monitoring and real-time session revocation UI are planned (Phase 5 Roadmap). Reference: Authentication Guide .

2.2 Audit and Accountability (AU)

NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
AU-2 / AU-3 Event Logging & Content	Structured Audit Event Logging: Captures inference requests, auth events, administrative changes, and API key mutations across SQLite, PostgreSQL, MongoDB, or Elasticsearch backends. Records timestamps, user IDs, masked keys, adapters, models, token counts, call types (chat , embedding , vision , stt , tts , image , video), and local cost estimates.	Provides audit event generation and detailed record content for security monitoring.	System integrators must enable <code>internal_services.audit.enabled: true</code> and configure a resilient storage backend. Login rate-limit events are recorded as <code>auth.login.rate_limited</code> ; extended coverage for password changes and failed logins remains planned (Phase 4 Roadmap). Reference: Token Usage and Cost Tracking .
AU-6 Audit Review & Reporting	Admin Observability & Cost Dashboards: Web UI Audit viewer and Costs tab enable filtering events by user, API key, adapter, provider, and call type with historical API key masking suffix resolution.	Supports administrative audit review, triage, and usage analysis.	Assessors must verify RBAC restrictions on audit routes (auditor / admin roles) and review audit log retention procedures. Reference: Token Usage and Cost Tracking .
AU-9 Audit Protection	Separate Admin Event Clearing: Setting <code>internal_services.audit.admin_events.clear_on_startup: false</code> preserves administrative and authentication audit history across server restarts even if inference logs are cleared.	Supports separate administrative audit-retention settings.	Deployment Responsibility: Log immutability, WORM storage, tamper-evidence, and remote syslog export must be implemented at the host/database layer. Reference: Default Configuration .
AU-10 Identity Attribution	Strict Auth Mode: Enabling <code>auth.require_authenticated_user: true</code> mandates that inference API calls carry a verified user identity alongside API keys.	Provides user-level attribution for API requests.	Deployment Responsibility: A bearer token provides attribution but not mathematical non-repudiation (tokens can be shared). Note: <code>/health</code> remains unauthenticated, and <code>/mcp</code> requires non-strict mode or separate routing. Reference: Authentication Guide .

2.3 Identification and Authentication (IA)

NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
IA-2 Identification & Authentication	OIDC/SSO Integration & Keyring: Supports Microsoft Entra ID (Azure AD) and Auth0 OIDC SSO protocols. Password authentication uses PBKDF2-SHA256 hashing. OS Keyring integration is available for credential storage.	Can participate in MFA enforced by the configured identity provider, and supports standard password hashing.	Integrators must enforce MFA at the OIDC Identity Provider level and verify OIDC discovery/callback endpoints. Roadmap Note (Phase 7): Native Two-Factor Authentication (2FA / TOTP) for local accounts is planned (Phase 7 Roadmap). Reference: Authentication Guide .
IA-5 Authenticator Management	API Key Management & Scoping: API keys are securely generated, stored and managed in the API-key store (<code>api_keys</code>), and masked in audit ledgers (<code>orbit_...</code>). Keys can be deactivated instantly (<code>active: 0</code>), bounded by request quotas, or restricted by user/email allowlists.	Supports key management, masking, and rapid deactivation.	Current Implementation Note: API keys do not currently feature automatic date-based expiration (<code>expires_at</code>); key rotation must be managed procedurally. Roadmap Note (Phase 8): An implementation plan (Phase 8 API Key Expiration Roadmap) details planned support for default 90-day key lifetimes, explicit admin renewal operations, auditable non-expiring exceptions, and legacy key migration. References: API Keys Guide , SQLite Schema .

2.4 System and Communications Protection (SC)

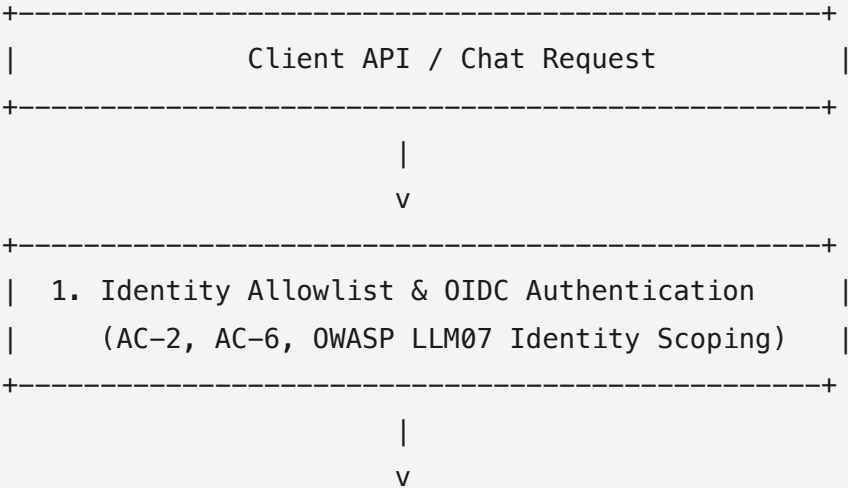
NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
SC-8 Transmission Confidentiality	HTTPS & TLS Encryption: Supports HTTPS over TLS 1.2 or later with forward-secrecy ciphers for REST endpoints, OpenAI-compatible proxy routes, and WebSockets (<code>/ws</code>).	Protects communications confidentiality and integrity in transit.	Operators must configure valid TLS certificates and enforce HTTPS termination at ORBIT or an upstream reverse proxy (e.g. NGINX). Reference: Server Guide .
SC-13 / SC-28 Cryptographic Storage	Opt-in File & Content Encryption: <code>files.encryption.enabled: true</code> combined with adapter <code>capabilities.requires_encryption: true</code> enforces AES-256-GCM encryption for stored file bytes, metadata sidecars, chunk text, and extracted content.	Protects uploaded document content at rest.	Roadmap Note: Cloud KMS integration, envelope encryption, and automated key rotation are documented future enhancement roadmap items. Reference: File Adapter Guide .

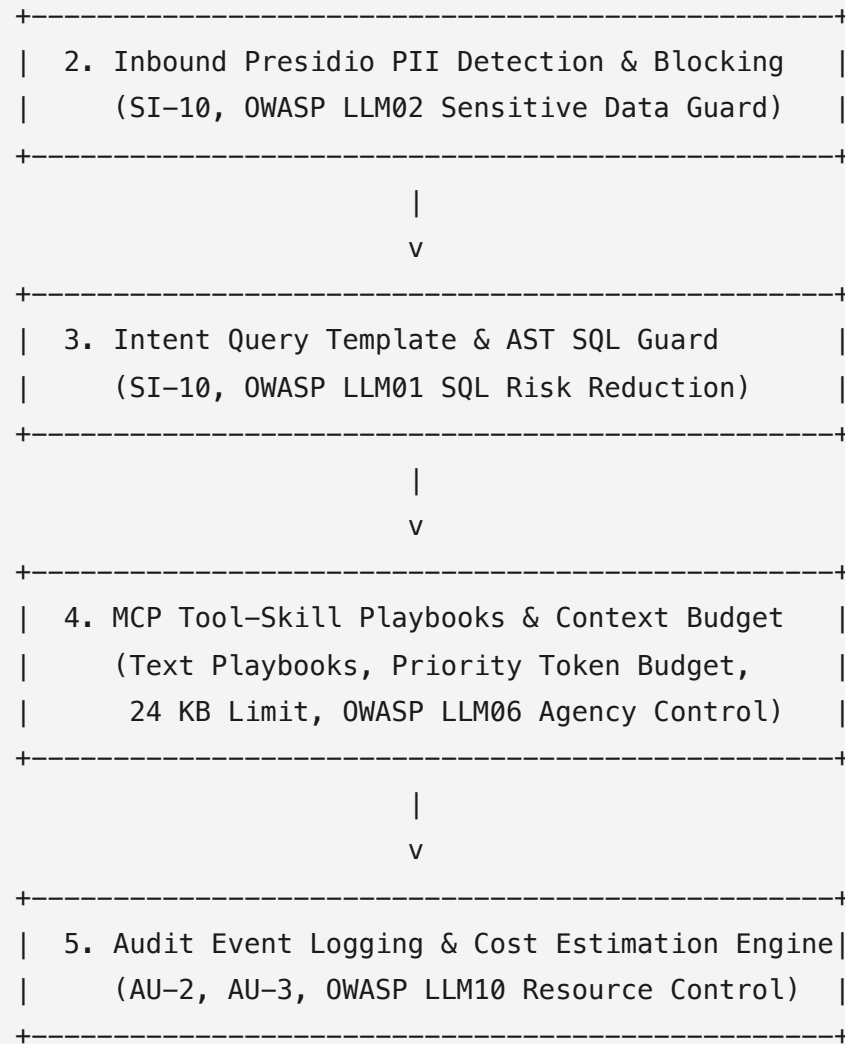
2.5 System and Information Integrity (SI)

NIST Control	Documented Capability	Potential Control Contribution	Deployment Evidence & Responsibilities Required
SI-4 System Monitoring	Metrics & Health Monitoring: Prometheus-compatible metrics endpoint (/ws/metrics), health checks (/health), worker status, circuit breakers, and rate-limiting telemetry.	Contributes to system monitoring and operational integrity tracking.	System administrators must connect /ws/metrics to enterprise monitoring tools (e.g. Prometheus/Grafana) and establish alerting rules. Reference: Default Configuration .
SI-10 Input Validation	Intent SQL Query Safety & File Verification: Intent-retrieval SQL execution paths parse generated queries with an AST validator enforcing single, read-only statements (SELECT). Uploaded files undergo MIME/magic-number checking via Magika .	Provides input validation over specific database query execution paths and uploaded files.	Limitations: Query guards apply specifically to intent-retrieval paths. Magika provides file-type verification, not antivirus/malware sandboxing or content disarm and reconstruction (CDR). Reference: Changelog (v2.15.3).

3. AI Security Guardrails & OWASP LLM Risk Mitigations

This section outlines technical guardrails in ORBIT that align with OWASP Top 10 for LLM Applications risk mitigation patterns.





3.1 OWASP LLM Top 10 Risk Mitigation Mapping

1. LLM01: Prompt Injection

- **Intent-Based Query Generation:** Natural language database questions match curated, configured query templates rather than invoking unconstrained LLM text generation over live databases.
- **AST SQL Query Guard:** Intent SQL retrievers parse generated queries using an AST validator enforcing single read-only statements (`SELECT`).
- **Prompt Prefix Stabilization:** System prompt prefixes are structured into static blocks for prompt-cache optimization. *(Note: Prompt prefix stabilization is a performance optimization, not a cryptographic or mathematical jailbreak defense).*

2. LLM02: Sensitive Information Disclosure

- **Inbound Presidio PII Moderation:** Evaluates incoming user prompts against Microsoft Presidio (HTTP REST service) for ~100 PII entity types with batch concurrency limits and safe serial fallback clamps. Flagged requests are blocked prior to model dispatch.
- **Local `privacy-filter` Model:** On-premises PII detection option for air-gapped environments. *(Note: `privacy-filter` fails open on technical errors and requires model files to be pre-staged in air-gapped deployments).*
- **Ungrounded Document Generation Guard:** Document generation skills refuse to generate filler content when requested file attachments are unretrieved or missing.

3. LLM06: Excessive Agency

- **MCP Tool Skills & Procedural Playbooks (`SKILL.md`):** Provides models with text-based procedural guidance for Model Context Protocol tools without granting unmonitored execution privileges.
- **Dual Injection Mechanism:** Supports explicit turn loading via an enum-scoped `orbit__load_tool_skill` loader and automatic post-invocation JIT injection (Phase 2). *(Note: JIT injection attaches after a bound tool's first call and does not shape the initial tool invocation).*

- **Turn Context Budget & Hard Limits:** Enforces a per-turn context budget (maximum 3 skills / 24 KB total per turn), catalog prioritization, and body-redacted audit logging.

4. LLM07: System Prompt Leakage & Supply Chain Security

- **Secrets Manager Resolution:** Resolves credentials from AWS Secrets Manager, Azure Key Vault, or GCP Secret Manager at startup, with fallback to environment/ `.env` values.
- **Model Scoping per Adapter:** Adapters support `allowed_models` configuration to restrict model selection choices per client request.

5. LLM10: Unbounded Consumption & Cost Controls

- **Request Quotas & Throttling:** Daily and monthly request quotas per API key with priority-based request throttling.
- **Local Cost Estimation:** Estimates token and media costs using an editable local rate table (`config/pricing.yaml`) with staleness tracking. *(Note: Costs are local estimations, not official cloud provider billing invoices).*

4. Alignment with NIST AI Risk Management Framework (AI RMF 1.0)

ORBIT's design supports organizational alignment with the four core functions of the **NIST AI RMF 1.0**:

- **GOVERN:** Enables version-controlled capability management (`config/*.yaml`), 6-role RBAC (`admin` , `operator` , `auditor` , `analyst` , `user-manager` , `user`), identity allowlists, and separate administrative audit-retention settings (`clear_on_startup: false`).
- **MAP:** Intent template validation maps natural language user queries to validated/configured SQL/API retrieval paths and explicit tool boundaries.
- **MEASURE:** Phase 4 intent telemetry tracks retrieval outcomes, confidence scores, and row caps, surfacing low-confidence queries in the Admin Panel **Misses** triage view.

- **MANAGE:** Integrated circuit breakers, provider fallbacks, and hot adapter reloading enable active management of provider outages and system updates without server downtime.
-

5. Security & Governance Enhancements Roadmap

ORBIT maintains an active security architecture roadmap to extend its security controls and address operational requirements for accredited environments:

5.1 Authentication & Access Control Hardening

- **Password Complexity Policies (Phase 2):** Configurable password strength criteria (minimum length, uppercase, lowercase, numeric, and special character rules) for local user account creation ([Phase 2 Roadmap](#)).
- **Account Lockout Controls (Phase 3):** Automatic account lockout after configurable consecutive failed login attempts with administrator unlock capabilities ([Phase 3 Roadmap](#)).
- **Expanded Audit Trail Coverage (Phase 4):** Extended audit event logging covering password modifications, failed login attempts, and session revocation ([Phase 4 Roadmap](#)).
- **Active Session Monitoring UI (Phase 5):** Real-time active session dashboard allowing administrators to inspect and revoke active user sessions on demand ([Phase 5 Roadmap](#)).
- **Admin Network IP Allowlisting (Phase 6):** CIDR-based network restriction (`auth.admin_ip_allowlist`) limiting administrative dashboard and API access to authorized management subnets ([Phase 6 Roadmap](#)).
- **Native Two-Factor Authentication (Phase 7):** Multi-factor authentication (MFA / TOTP) support for local administrative accounts ([Phase 7 Roadmap](#)).
- **API Key Expiration & Lifecycle Management (Phase 8):** Enforceable key expiration (`expires_at` , 90-day default lifetime), explicit admin renewal workflows, auditable non-expiring exceptions, and legacy key migration ([Phase 8 Roadmap](#)).

5.2 Cryptography & Data Protection

- **Cloud KMS & Envelope Encryption:** Cloud KMS, envelope encryption, and key rotation: planned future enhancement; see the file-encryption roadmap ([File Encryption Roadmap](#)).

5.3 Resource & Budget Governance

- **Real-Time Cost Alerts & Notifications:** Configurable spend thresholds, budget notifications, and automated alerts for API key and tenant usage ([Cost Notifications Roadmap](#)).
-

6. Document References

- **NIST SP 800-53 Rev. 5:** [NIST CSRC Publication Detail](#)
- **NIST AI RMF 1.0:** [NIST AI Risk Management Framework](#)
- **OWASP Top 10 for LLM:** [OWASP LLM Security Project](#)
- **ORBIT Capability Matrix:** [ORBIT Capability Matrix](#)
- **ORBIT Authentication Guide:** [Authentication Guide](#)
- **ORBIT PII Moderation Guide:** [PII Moderation Guide](#)
- **ORBIT Role-Based Access Control:** [RBAC Architecture](#)